

University of Florence

An OWL-Based Ontology for NIS2 Article 21 Compliance

Automated validation and reasoning for cybersecurity risk-management measures

OWL 2 DL

SHACL

SPARQL

Candidate: Abdul Kader

Supervisor: Prof. Enrico Francesconi

Goal: turn legal obligations into a computable compliance model

What this thesis delivers

Problem

Manual NIS2 Article 21 checking is slow and inconsistent

Method

Ontology engineering with OWL, SHACL, SPARQL, and a web app

Outcome

Automated gap detection and compliant / non-compliant classification

Scope

Category-level compliance support, not legal certification

10-minute presentation version, 10 slides

Agenda and thesis story

1. Problem

Why Article 21 compliance is difficult to verify with manual documents and checklists.

2. Solution

How the ontology, SHACL shapes, SPARQL queries, and web UI work together.

3. Outcome

What the prototype can infer, validate, and demonstrate for real compliance reviews.

Presentation flow

- Context and research gap
- Formal model and design choices
- Implementation and demonstration
- Evaluation, limits, and next steps

Key message

The contribution is not a full legal decision engine. It is a structured and traceable way to turn NIS2 Article 21 into a machine-readable compliance model that can highlight gaps quickly.

The problem

Why verification is difficult

- Article 21 requires multiple technical, operational, and organizational measures.
- Evidence is usually stored in documents, spreadsheets, and team knowledge.
- Reviewers must manually judge coverage, consistency, and missing controls.
- The result is slow, error-prone, and hard to reproduce across entities.

Research gap

- No machine-readable OWL model for Article 21(2) compliance in the thesis scope.
- No built-in way to infer compliance class membership from implemented measures.
- No compact validation layer that can expose missing categories directly.

Problem statement in one sentence

We need a way to model NIS2 Article 21 compliance so that a computer can check measure coverage, explain gaps, and keep legal traceability.

Research objective and contribution

Research objective

- Represent the 10 legal categories of Article 21(2) as 12 operational OWL classes.
- Classify an entity as compliant when it implements every required category.
- Use SHACL to surface missing or incomplete compliance evidence.

Main contribution

- A usable OWL 2 DL ontology in Turtle and RDF/XML.
- A structured compliance-checking workflow with validation and reasoning.
- A web application for graph exploration, queries, and entity checks.

What is novel here

- The compliance class is defined formally, not only described verbally.
- The ontology keeps legal provenance and technical traceability together.
- The system supports explanation, not just a binary answer.

Research questions answered by the prototype

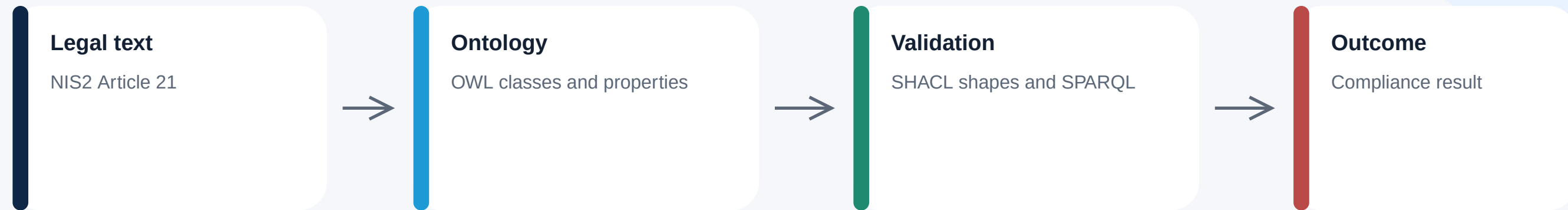
Can Article 21(2) be represented as a layered ontology?

Which OWL axiom pattern best captures category coverage?

How do SHACL and OWL complement each other?

Can the model support SPARQL-based analysis and real-time checking?

How the solution works



Ontology pattern

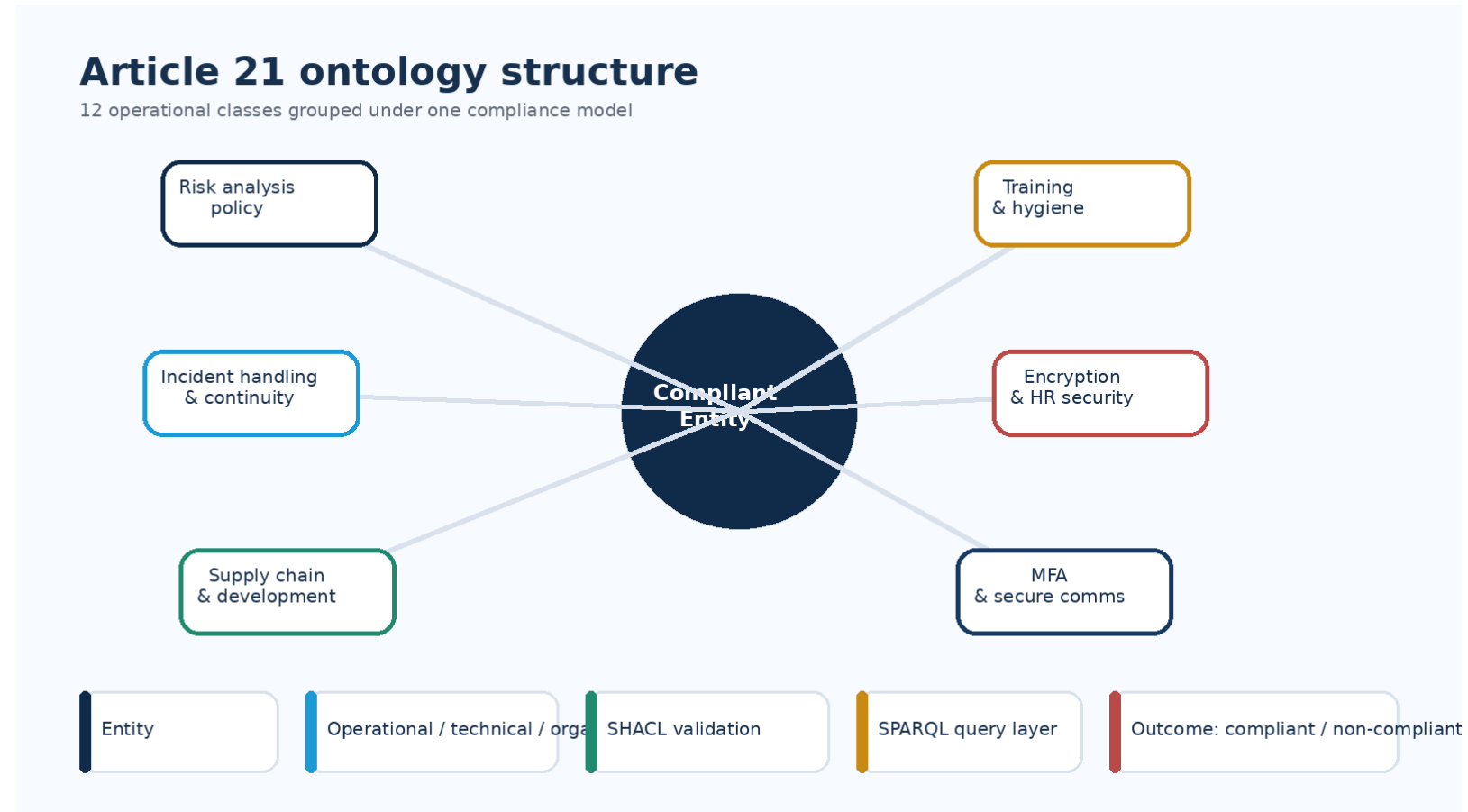
The core axiom defines `CompliantEntity` as an `Entity` that implements at least one instance of each required measure class. Because Article 21(2) has ten legal points, the thesis models them as twelve operational classes by splitting point (g) and point (j).

Validation pattern

- SHACL catches missing categories and incomplete inputs.
- SPARQL exposes entities, measures, and coverage summaries.
- The web app makes the ontology usable without editing RDF directly.

Ontology design

Class structure



Real ontology groups the 12 operational classes under one compliance entity.

Core model

- Base classes: Entity, RiskManagementMeasure, CybersecurityRisk, SecurityIncident, NetworkInfo
- Measure families: Technical, Operational, Organizational.
- Properties connect measures to risks, incidents, systems, and standards.

Why this matters

- The model stays traceable to Article 21 references.
- It supports consistent classification across cases.
- It separates legal categories from implementation evidence.

Implementation and architecture

Data tier

OWL/Turtle ontology, SHACL shapes, example entities

Service tier

Express backend for ontology loading, validation, SPARQL, and reasoning

User tier

Interactive graph visualizer and compliance checker in the browser

OWL 2 DL

formal semantics

SHACL

shape validation

SPARQL

query layer

vis-network UI

graph exploration

Implementation facts

- Ontology size: 603 triples
- Validation rules: 3 SHACL shapes

● Example entities show both compliant and non-compliant paths

Demonstration and evaluation

Worked example

Art. 21(2)	Legal obligation (abbreviated)	State of affair	Verdict
(a)	Risk analysis and information system security policies	Med Center Risk Analysis Policy implemented	COMPLIANT
(b)	Incident handling procedures and capabilities	Med Center Incident Handling implemented	COMPLIANT
(c)	Business continuity, backup management, disaster recovery	No measure asserted	VIOLATION
(d)	Supply chain security and supplier relationships	No measure asserted	VIOLATION
(e)	Security in NIS acquisition, development and maintenance	No measure asserted	VIOLATION
(f)	Policies to assess effectiveness of risk measures	No measure asserted	VIOLATION
(g)	Basic cyber hygiene practices and training	Basic Cyber Hygiene + Training Awareness	COMPLIANT
(h)	Policies regarding cryptography and encryption	Med Center Encryption implemented	COMPLIANT
(i)	Human resources security, access control, asset mgmt	No measure asserted	VIOLATION
(j)	MFA / continuous authentication + secured communications	MFA only; no Secure Communications	PARTIAL

Article 21(2)(j) warrants special attention: the ontology decomposes this norm into two operational classes — MultiFactorAuthentication and SecureCommunications — because the directive text covers both authentication solutions and secured voice/video/text communications. MedCenterHospital satisfies the authentication component but not the communications component. The ontology makes this decomposition explicit, allowing the compliance verdict to distinguish between two obligations encoded within a single legal paragraph.

8.14.7 Compliance Verdict and Remediation Path
The formal verification of MedCenterHospital against the NIS2 Article 21 ontology yields the following outcome:

- OWL 2 DL inferred classification: :NonCompliantEntity
- SHACL result: INVALID — 6 sh:Violation, 0 sh:Warning on implemented measures

Page | 81

Extract from the thesis showing the partial healthcare case and verdicts.

Observed result

- A partial healthcare entity demonstrates the non-compliant path.
- A complete synthetic entity demonstrates the compliant path.
- The thesis makes the verdict explainable by naming each missing category.

What the evaluation shows

12 / 12

Full coverage leads to `CompliantEntity` inference.

6 / 12

Partial coverage stays non-compliant and reveals gaps.

Important interpretation The compliance score is a coverage indicator, not a legal certification or a risk-weighted maturity score.

Limitations and future work

Comparison with existing approaches

9.5 Comparison with Existing Approaches

The implemented framework is compared against three categories of existing approaches:

Approach	Formal Semantics	Auto Reasoning	SPARQL	SHACL	Open Source
This thesis (OWL+SHACL)	Yes (OWL 2 DL)	Yes	Yes	Yes	Yes
Commercial GRC tools	No	No	No	No	No
ENISA checklist	No	No	No	No	Yes
Hassan 2025 (Legal Ontology)	Yes (OWL 2 DL)	Yes	Yes	No	Yes
Manual audit	No	No	No	No	N/ A

The comparison shows that the prototype combines several capabilities in one demonstrator. It should not be read as evidence that it is more complete than every commercial or academic alternative, because the compared categories differ in scope, evidence management, workflow, assurance, and production maturity.

9.6 Competency-Question Evaluation

All five competency questions can be expressed using the ontology vocabulary and executed through the query interface. Returned bindings correspond to manually inspected triples and expected inference paths.

This confirms functional adequacy for the declared information needs and demonstrates that the conceptual model supports risk, standard, incident, system, and implementation analysis.

The selected questions use a bounded query subset and do not establish complete SPARQL 1.1 conformance.

9.7 Error Analysis and Negative Cases

The incomplete asserted entity produces seven expected missing-class results rather than a generic failure. Additional partial cases can be generated through /api/check-entity.

Specific reporting supports diagnosis and remediation. The observed SHACL-oriented violations correspond to the absent operational classes in the tested graph.

The small synthetic dataset cannot estimate behavior under noisy data, inconsistent typing, duplicate controls, or disputed mappings.

Page | 85

The thesis combines OWL semantics, SPARQL, SHACL, and a web interface in one demonstrator.

Current limitations

- Reasoning service is bounded and not a full OWL 2 DL engine such as HermiT or Pellet.
- SPARQL support is limited compared with a standards-complete endpoint.
- The prototype relies on asserted booleans and does not validate full evidence semantics.
- The system is a thesis prototype, not a production compliance platform.

Next steps

- Connect to a full reasoner and standards-complete SPARQL engine.
- Add evidence objects, provenance, dates, and review metadata.
- Extend beyond Article 21 to broader NIS2 obligations.
- Test with realistic datasets and practitioner review.

Practical takeaway

Present the thesis as a formal compliance framework and demonstration, not as a production-grade legal certification tool.

Conclusion

Final message

We turned Article 21 compliance into an OWL-based model that can reason about implemented measures, validate missing categories, and explain results in a compact web application.

That is the main contribution: structured, traceable, and reusable compliance checking.

Three takeaways for the audience

- The problem is real: manual verification does not scale well.
- The solution is formal: OWL gives the legal model meaning and inference.
- The result is practical: SHACL and the UI expose gaps clearly.

If asked to summarize the thesis in one sentence:

A formal ontology can make NIS2 Article 21 compliance checks more consistent, explainable, and reusable.